IT & INFORMATION SECURITY POLICIES

Enterprise Password, Access Control & Credential Security Policy

Complexity Rules, MFA Mandates, JIT Access, and Account Compromise Protocols

Classification: Confidential **Version:** 4.0 **Owner:** Information Security **Standard:** NIST SP 800-63B / SOC 2

1. Purpose and Regulatory Framework

This policy defines mandatory requirements for password security, multi-factor authentication (MFA), role-based access control (RBAC), and credential compromise handling across Apex Global Technologies. This policy is aligned with **NIST Special Publication 800-63B (Digital Identity Guidelines)** and **SOC 2 Type II** trust services criteria.

2. Password Complexity and Passphrase Standards

- **Minimum Length:** All standard employee accounts must use passwords of at least **14 characters**. Privileged administrative accounts (AWS root/IAM admin, database DBA, Kubernetes cluster-admin) require at least **16 characters**.
- **Complexity:** Must contain at least one uppercase letter, one lowercase letter, one numeric digit, and one special symbol (`!@#$%^&*()_+-=`). Passwords may not contain common dictionary words, user names, company names, or predictable numeric sequences.
- **Passphrase Recommendation:** Employees are strongly encouraged to use multi-word passphrases consisting of at least four randomly chosen words (e.g., `correct-horse-battery-staple-2026!`).
- **Expiration & Rotation Policy:** In compliance with NIST SP 800-63B, forced arbitrary 90-day password rotation is discontinued. Passwords must only be rotated upon suspicion of compromise or when detected in threat intelligence credential dumps.

3. Multi-Factor Authentication (MFA) Requirements

MFA is universally enforced across all corporate systems, including Okta SSO, Google Workspace, GitHub Enterprise, AWS, and the GlobalProtect VPN:

- **Approved MFA Methods:** Hardware FIDO2/WebAuthn security tokens (YubiKey 5 Series) are the mandatory primary factor. Software TOTP apps (Okta Verify, Google Authenticator) are authorized secondary fallbacks.
- **Prohibited MFA Methods:** SMS-based and voice-call verification are strictly prohibited due to known SIM-swapping, SS7 redirection, and interception vulnerabilities.

4. Protocol for Suspected Account Compromise

EMERGENCY ACTION PROTOCOL: What should an employee do if they suspect an account compromise?

If an employee suspects unauthorized access, observes anomalous login alerts, detects altered files, or fears credentials were entered on a phishing site, they must execute the following **immediate four-step protocol**:

1. **Isolate Device from Network:** Immediately disconnect the device from corporate Wi-Fi or unplug the Ethernet cable, and disconnect the GlobalProtect VPN. Do NOT power off or reboot the workstation, as volatile memory contains vital forensic evidence.
2. **Immediate Incident Reporting:** Contact the Security Operations Center (SOC) immediately via:
   - **Emergency Phone Hotline:** +1-888-APEX-SEC (+1-888-273-9732, staffed 24/7/365).
   - **Dedicated Slack Channel:** `#sec-ops-emergency`.

    - **SOC Dispatch Email:** `security-incident@apextech.internal`.

3. **Trigger Immediate Session Revocation:** From a secondary trusted mobile device, log in to the Okta Self-Service Security Portal and select *"Revoke All Active Sessions & Reset Password"*, or request an immediate administrative lock from IT Helpdesk.
4. **Assist Forensics & Preserve Custody:** Provide a written timeline of observed anomalies to the Incident Response Lead and keep the affected workstation locked for IT security collection.

5. Access Control, Least Privilege, and User Reviews

- **Principle of Least Privilege:** Access to production databases, cloud infrastructure, and customer data is denied by default and granted solely on documented business justification.
- **Just-in-Time (JIT) Elevation:** Administrative access is granted through temporary elevation (AWS IAM Identity Center / Teleport) with automatic expiration after 4 hours.
- **Quarterly Access Audits:** Department managers must review and re-certify user access permissions every 90 days. Uncertified access is revoked automatically.